

学生管理系统 • 完整实现报告

# 基于 Jakarta Web 与 Hibernate 的 学生管理系统现代化改造 设计与实现

Design and Implementation of a Modernized  
Student Management System

学校 / 院系: \_\_\_\_\_

作者姓名: \_\_\_\_\_

学号: \_\_\_\_\_

指导教师: \_\_\_\_\_

项目: studentManagerSix

实施与验收日期: 2026年9月8日

PDF 复核整理版

## 摘要

针对传统学生管理工程存在的依赖混用、配置冲突、事务边界不清和访问控制缺失，本文在保留 JSP、Servlet、Service、DAO、Hibernate 与 MySQL 技术路线的基础上实施现代化改造。系统采用统一 Maven 构建和 Docker Compose 部署，建立学生档案与独立账户模型，实现管理员增删改查、搜索分页，以及学生注册、本人资料维护和密码修改。通过服务层统一事务、PBKDF2 密码哈希、角色过滤、CSRF 校验与账户版本核查，改善数据一致性和会话控制。实际验收包含 4 个单元测试、1 个真实 MySQL 集成场景、85 项含重启 HTTP 断言及浏览器交互；相关测试均通过。结果表明当前版本具备本机教学与作品演示所需的可构建、可运行和可验证能力。本文同时明确公网部署、压力测试、旧库迁移及空闲超时计时验证尚未完成。

关键词：学生管理系统；Jakarta Web；Hibernate；事务一致性；访问控制；Docker

## 报告说明

本报告根据代码主目录中的实现、SQL、构建配置、已有测试记录及界面截图重新核对并排版。测试结果沿用2026年9月8日保存的验收证据；此次文档整理未重新执行完整应用验收。作者及院校资料待填写。

# Abstract

This report documents the modernization of an existing student management application while retaining its JSP, Servlet, Service, DAO, Hibernate and MySQL architecture. A Maven build and Docker Compose deployment replace inconsistent legacy configurations. Separate student and account models support administrator CRUD, search and pagination, student registration, profile maintenance and password changes. Service-level transactions, PBKDF2 hashing, role checks, CSRF validation and authentication versions establish explicit consistency and access boundaries. Verification includes four unit tests, one real MySQL integration scenario, 85 HTTP assertions with restarts, and browser interactions. The evidence supports local demonstration use; public deployment, load testing and legacy database migration remain outside the verified scope.

Keywords: student management; Jakarta Web; Hibernate; transaction consistency; access control; Docker

# 目录

|                |    |
|----------------|----|
| 摘要             | 2  |
| Abstract       | 3  |
| 第一章 绪论         | 5  |
| 第二章 原工程分析与需求定义 | 6  |
| 第三章 技术选型与总体架构  | 7  |
| 第四章 数据库设计与一致性  | 8  |
| 第五章 身份认证与访问控制  | 9  |
| 第六章 业务功能实现     | 10 |
| 第七章 界面与工程实现    | 11 |
| 第八章 构建部署与运行复现  | 12 |
| 第九章 测试方法与结果分析  | 13 |
| 第十章 总结与后续工作    | 14 |
| 附录 A 数据库字典     | 15 |
| 附录 B 功能接口与输入规则 | 16 |
| 附录 C 测试证据与断言清单 | 17 |
| 附录 D 部署与复现     | 21 |
| 附录 E 参考资料与代码索引 | 23 |
| 附录 F 实际界面图录    | 25 |

# 第一章 绪论

## 1.1 研究背景与问题提出

学生档案管理的基本需求包括准确保存身份资料、按条件检索、维护账户以及控制不同角色的操作范围。传统课程项目能够说明 JSP、Servlet 和 Hibernate 的调用关系，但当工程配置、依赖和数据访问代码逐步累积时，运行环境难以复现，功能完整性和访问控制也容易出现断层。本项目以既有 studentManagerSix 工程为对象，围绕能够构建、能够运行、能够验证的目标开展现代化改造。

## 1.2 研究目标与边界

改造保留 JSP → Servlet → Service → DAO → Hibernate → MySQL 技术路线，在原目录形成统一的 Maven WAR 工程。目标是补齐管理员与学生两类角色的业务闭环，明确事务和会话边界，建立可重复的容器运行与验收流程。报告记录的是本机课程与作品演示版本；公网运行、旧生产数据库迁移、压力测试和跨组织身份管理不属于本次已完成范围。

## 1.3 实施方法与报告组织

实施采用原工程调查、需求梳理、分层重构、数据建模、业务实现和分级验收的顺序。针对发现的问题建立问题与措施映射，并通过源码、SQL、构建配置、测试报告和浏览器截图相互核对。本文正文说明设计依据与关键实现，附表提供可查询的数据字典、路由、测试断言和复现步骤。技术版本以本次交付配置为准，不将其表述为长期不变的最新版本。

## 第二章 原工程分析与需求定义

### 2.1 原工程结构与运行障碍

原工程同时保留 Eclipse Java 6、IDEA Java 15 和绝对 Tomcat 路径，源码、字节码与手工依赖混放。WEB-INF/lib 中的 Hibernate 3 与根 lib 中 Hibernate 5.4 形成混用风险。残留 JDBC 实现的 getStudent 返回 int，而 DAO 接口声明 List<Student>，导致全量源码无法一致编译。上述问题说明首先需要统一构建边界，而非仅修补页面跳转。[R1][R2]

### 2.2 业务与安全缺口

原登录流程主要完成页面跳转，没有可靠的登录身份和角色隔离；删除可以通过 GET 触发，密码使用短明文存储并可能出现在列表中。部分 DAO 自行开启事务，查询未完成事务，删除又嵌套事务，异常被吞掉后调用方难以判断失败原因。列表依赖 Session 和 JSP Java 脚本片段，缺少编辑、搜索和退出等完整操作链。

### 2.3 功能需求

管理员需要创建学生及其登录账户、查询列表和详情、编辑资料、删除档案与关联账户，并按学号或姓名检索。学生需要公开注册、学号登录、查看并修改本人资料，以及修改密码和退出。两类用户共用身份验证与密码机制，但学生不能读取管理目录或通过表单参数操作其他人的档案。学号创建后保持不变，避免标识更新引起外键和登录名不一致。

### 2.4 非功能需求与验收准则

数据变更必须具有原子性，失败时不得留下只有学生而没有账户的中间记录。所有查询使用参数绑定，页面输出转义，修改请求验证 CSRF 令牌。工程应能从统一依赖构建 WAR，并通过 Compose 在隔离数据库上运行。桌面与手机页面需要可操作；页面不应整页横向溢出，窄屏表格允许局部滚动。验收证据需区分配置核查、自动请求和真实浏览器操作。

## 第三章 技术选型与总体架构

### 3.1 运行平台与依赖管理

工程采用 Java 25、Maven 3.9.16、Tomcat 11.0.25 和 Hibernate ORM 7.4.7.Final，数据库为 MySQL 9.7.1。Servlet 6.1、JSP 4.0 与 Jakarta Persistence 3.2 构成 Jakarta 技术体系。Maven Wrapper 固定构建入口，pom.xml 统一依赖，旧 JAR 不进入新构建。Servlet、JSP 与 EL API 采用 provided 作用域，由运行容器提供，减少重复 API 引发的类加载问题。[R3][R6-R9]

### 3.2 分层职责与调用流程

浏览器请求先进入 WebSecurityFilter，完成字符编码、登录状态、账户版本、角色和 CSRF 检查；StudentServlet 负责路径分派、参数解析和视图选择；StudentServiceImpl 负责业务规则和事务；DAO 在调用方传入的 Session 上完成类型化查询与实体持久化。Hibernate 经 HikariCP 连接 MySQL。JSP 位于 WEB-INF/views，只由控制器转发访问，通过 EL 和 Jakarta Tags 展示结果。

### 3.3 生命周期与并发边界

AppLifecycle 在应用启动时创建共享 SessionFactory 与无请求状态的 Service，应用停止时关闭工厂和连接池。Hibernate Session 在每个服务操作中单独创建，不跨线程共享。查询结果在事务内准备完整，页面无需依赖仍然打开的数据库会话。Session 保存身份、CSRF 和一次性提示，列表数据放在 request，从而避免把整份学生目录长期保留在用户会话中。

### 3.4 请求完成模式

读取操作直接转发 JSP，新增、编辑等成功提交后采用 POST/Redirect/GET，降低刷新页面重复提交的可能。业务错误通过明确状态和中文提示反馈，内部错误记录到服务端。权限控制由 Filter 和 Service 的实际身份依据共同约束，而不是依赖隐藏按钮。页面可见性改善使用体验，服务器检查才决定请求能否执行。

## 第四章 数据库设计与一致性

### 4.1 实体划分

`student` 表保存学号、姓名、年龄与地址；`account` 表保存登录名、密码哈希、角色、关联学号和认证版本；`app_seed` 表保存演示初始化标记。将账户与档案拆分，使管理员能够拥有登录身份而无需虚构学生档案，也使密码材料不会作为学生列表字段返回。学生账户的 `student_sno` 唯一并引用 `student.sno`，形成每个学生至多一个关联账户的关系。[R4]

### 4.2 约束与校验协作

数据库通过主键、唯一键、外键和 `CHECK` 约束限制非法状态：学号大于零，年龄为 1 至 150，管理员不得关联学生，学生角色必须关联学生。服务端在进入持久化前校验姓名、地址、密码及整数范围，提供可理解的错误提示；数据库约束作为最后防线。字符串采用 `utf8mb4`，支持中文和补充 Unicode 字符。具体字段类型与可空性见数据字典。

### 4.3 事务策略

每个业务操作使用一个 `Session` 和一个事务，成功提交，异常回滚，并在结束时关闭 `Session`。学生创建与账户创建处于同一事务；删除先移除关联账户再移除学生，避免外键错误与孤儿记录。集成测试故意使账户插入违反约束，验证先写入的学生也被撤销，并继续执行后续操作，证明失败不会破坏后续连接使用。

### 4.4 初始化与数据持久化

数据库初始化 SQL 只针对新建数据卷执行，Hibernate 启动仅执行结构 `validate`，不自动修改表。应用将管理员、十条示例学生、账户哈希和初始化标记置于同一事务中；已有标记时不重复导入，因此重启不重置修改后的资料和密码。Compose 使用 `student-data` 命名卷保存数据库。此机制解决演示数据初始化问题，不等于已实现旧库迁移或生产备份恢复。

## 第五章 身份认证与访问控制

### 5.1 密码存储与验证

Passwords 使用 PBKDF2-HMAC-SHA256，配置 600000 次迭代、16 字节随机盐和 256 位派生结果。存储串包含算法、版本、迭代参数、盐和结果，便于解析与拒绝异常格式。相同密码因随机盐得到不同存储值，比较使用恒定时间方法。未知用户名也执行伪哈希验证，减少明显的处理路径差异。报告不展示实际账户密码或数据库连接秘密。[R5]

### 5.2 会话建立与撤销

登录成功更换 Session ID，降低会话固定风险；会话配置 30 分钟空闲超时，Cookie 设置 HttpOnly 与 SameSite=Lax，Secure 由运行环境开关控制。Identity 保存认证所需信息，受保护请求重新核查账户存在与 auth\_version。修改密码递增该版本，使所有旧会话失效；删除账户后原有会话同样失去访问能力。空闲超时已核对配置，但未实际等待 30 分钟计时。

### 5.3 角色与对象级权限

公开注册由服务器固定创建 STUDENT，忽略客户端提交的管理员角色。管理员访问学生管理路由，学生访问个人资料路由。个人资料更新使用当前 Identity 中的学号，不采用请求提供的目标学号，因此即使篡改参数也只能更新本人。管理员账号不关联学生档案，不通过学生删除入口移除。角色检查与对象选择共同构成权限边界。

### 5.4 请求与输出防护

所有 POST，包括登录与退出，要求会话同步 CSRF 令牌；删除只接受 POST，GET 删除返回 405。查询使用命名参数，姓名搜索额外转义 LIKE 中的百分号、下划线和转义字符，确保它们作为文字匹配。JSP 通过 c:out 转义用户输入，本地静态资源配合 CSP 限制内联脚本，并设置 no-store。上述措施覆盖已实现的常见边界，不代表已经完成全面渗透测试。

## 第六章 业务功能实现

### 6.1 注册与管理员创建

注册和管理员新增都先校验学号、姓名、年龄、地址及密码，然后在同一事务中建立档案与账户。学生登录名使用规范化学号字符串，避免数值标识与文本登录名不一致。重复学号返回 409，非法参数返回 400。注册完成后用户通过登录建立会话；管理员新增完成后返回管理流程。具体处理入口集中在 StudentServlet，数据一致性由服务层维护。

### 6.2 查询、详情与分页

列表默认每页 10 条，按 sno 升序保持稳定排序。学号采用精确条件，姓名采用文字关键词条件，结果与总数对应相同过滤条件。PageResult 提供当前页、页大小、总记录数和总页数，支持前后页链接并保留搜索条件。空页码按第一页处理，负页码调整为 1，超过末页定位末页，非整数页码返回 400；无结果时展示空状态。

### 6.3 编辑、删除与个人资料

管理员可查看详情和编辑姓名、年龄、地址，学生可维护本人相同字段；学号保持不变。删除在同一事务中移除账户和档案，界面提供确认交互，服务器再次执行身份、CSRF 与目标存在性检查。记录不存在返回 404。浏览器验收分别操作了取消和确认删除，避免仅凭服务端请求通过就推断交互流程正确。

### 6.4 密码修改与退出

密码修改验证当前凭据及新密码规则，保存新哈希并递增认证版本；旧密码不能再次登录，另一个已登录会话也会在后续受保护请求中失效。退出使用 POST 并撤销当前会话。该设计既提供账户自行维护能力，也将会话撤销建立在服务端状态核查上。测试覆盖改密、重新登录、旧会话失效和账户删除后的失效行为。

## 第七章 界面与工程实现

### 7.1 中文页面与响应式布局

界面使用中文 JSP 模板、本地 CSS 和 JavaScript，提供登录、学生列表、详情、表单与个人维护页面。桌面侧栏固定在可见区域；手机界面保留可见退出口，宽表格在容器内滚动，避免整页横向溢出。页面验证使用  $1440 \times 1000$  和  $390 \times 844$  视口，图录保留实际页面截图。部分截图为全页截取，其图片高度不等于测试视口高度。

### 7.2 Jakarta 升级中的兼容性修正

联调发现 Jakarta EL 6 对 record 按访问器名称解析属性，为 Identity 补充 admin 访问器解决角色展示问题。JSP 主页面和静态包含文件分别声明 UTF-8，修复部分中文解码异常。Jakarta EL API 改为 provided，避免标签依赖把旧 EL API 打入 WAR。本地 SVG 图标补齐后，最终浏览器控制台未见错误。这些问题说明依赖升级需要真实容器渲染验证。

### 7.3 工程清理与原始资料保留

新工程使用 `src/main/java`、`src/main/webapp`、`src/test` 和 `docker/init` 等标准目录；legacy 保存旧源码、JAR 与 IDE 配置，不参加编译、Docker 构建或新源码发行包。另保留原始 ZIP 快照以便追溯。当前 WAR 经检查未混入旧 Hibernate/JDBC 类和重复的容器 API。XLSX 原报告和本 PDF 报告均置于代码主目录，作为本次实现的文档交付物。

## 第八章 构建部署与运行复现

### 8.1 容器构建与启动

Dockerfile 使用多阶段构建，构建阶段通过 Maven 生成 studentManagerSix.war，运行阶段部署到固定补丁版本 Tomcat 镜像。Maven 缓存用于减少重复下载，运行用户为非 root UID 10001。Compose 编排 app 和 db，应用端口绑定 127.0.0.1，数据库不向主机映射端口。首次运行需要下载镜像与依赖，启动后应同时检查两个服务健康状态。[R3]

### 8.2 健康检查与故障排查

原容器探针依赖 curl，但官方 Tomcat 镜像不包含该命令，导致进程运行与健康判定不一致。最终增加 HealthProbe，使用 JDK HttpURLConnection 请求健康接口，设置连接和读取超时，并检查 HTTP 200 与 OK 响应。实际 Compose --wait 验证 app 和 db 为 healthy。运行排障应联合查看服务状态、应用日志与数据库连通性，而非仅判断端口是否打开。

### 8.3 环境配置与数据保留

新副本可从 .env.example 创建 .env 并设置初始化密码、数据库密码和应用端口。已有数据卷不会因为修改环境中的示例密码而重置账户。普通停止、启动与 down 保留命名卷；保留数据时不能使用 down -v。手动部署需先在独立数据库执行建表 SQL，再配置 Tomcat 环境变量。HTTPS 场景应启用 Secure Cookie，但公网 HTTPS 接入并未纳入本次验收。

## 第九章 测试方法与结果分析

### 9.1 分级验证策略

验证分为工具类单元测试、真实 MySQL 集成场景、HTTP 端到端请求和浏览器交互四层。单元测试验证密码与输入边界；集成测试验证事务、数据库约束和初始化；HTTP 脚本覆盖业务及访问控制；浏览器验证实际表单、删除确认和屏幕布局。不同层证据不能简单相加为覆盖率，也不能用请求成功代替用户交互检查。[R10]

### 9.2 自动化执行结果

JUnit 报告记录 PasswordsTest 两个测试、ValidationTest 两个测试和 StudentServiceIT 一个完整集成场景，均为零失败、零错误、零跳过。含数据库和应用重启的 HTTP 记录有 85 项通过断言；页面修正后的回归记录为 77 项。断言包括重复的表单渲染及登录辅助检查，85 和 77 属于不同执行记录，不能合计为 162 个独立测试用例。测试证据页逐条保留 85 项原始标签。

### 9.3 关键边界与持久化结果

已验证学生不能访问管理员路由，伪造注册角色无效，篡改个人资料学号不能修改他人；缺少 CSRF 返回 403，GET 删除返回 405。HTML 输入被转义，百分号和下划线按文字搜索，中文与 emoji 可保存。强制账户约束失败能回滚学生插入。依次重启数据库和应用后，新建记录、修改后的资料及密码仍在，种子数据不会覆盖修改；临时测试记录清理后恢复十条示例学生。

### 9.4 结论适用范围

上述结果支持当前本机演示版本的构建、业务闭环、角色限制和持久化行为。报告没有提供性能基准、代码覆盖率或外部安全审计结论，不能据此推导高并发容量与生产合规性。30 分钟空闲过期仅完成配置核查。测试运行耗时是当次报告值，不代表稳定性能指标；普通 mvn verify 未配置 TEST\_DB\_URL 时会跳过数据库集成测试，复现必须使用隔离 Compose 流程。

## 第十章 总结与后续工作

### 10.1 实现总结

本次工作将混合旧依赖和不一致 IDE 配置的传统工程整理为可复现的 Maven 与 Docker 项目，保留课程所需的 Servlet、Service、DAO 和 Hibernate 分层。功能方面形成管理员管理与学生自助维护闭环；数据方面建立独立账户、关系约束和统一事务；访问控制方面实现服务器角色判断、本人范围限定、CSRF 和可撤销会话。实际测试记录与截图为交付提供了可检查依据。

### 10.2 局限与改进方向

后续若面向真实使用，应另行设计旧数据迁移及密码重设、备份恢复演练、HTTPS 与秘密管理、登录限速、审计日志、监报告警和容量测试，并按照真实使用场景制定验收指标。上述内容属于建议，不是本版本已实现功能。学校、作者、学号和指导教师信息尚未提供，封面保留填写位置；提交院校论文前还需依照其模板调整署名与格式。

## 附录 A 数据库字典

依据 docker/init/001-schema.sql 核对，共3张表、11个字段。student 与 account 明确使用 utf8mb4 / utf8mb4\_0900\_ai\_ci；app\_seed 仅包含整数标记。

| 表        | 字段            | 类型           | 可<br>空 | 键 / 默认      | 用途与约束                                  |
|----------|---------------|--------------|--------|-------------|----------------------------------------|
| student  | sno           | INT          | 否      | PK          | 学号；CHECK sno > 0                       |
| student  | sname         | VARCHAR(20)  | 否      | -           | 学生姓名                                   |
| student  | age           | INT          | 否      | -           | 年龄；CHECK 1 至 150                       |
| student  | address       | VARCHAR(50)  | 是      | -           | 地址                                     |
| account  | id            | BIGINT       | 否      | PK / 自增     | 账户标识                                   |
| account  | username      | VARCHAR(64)  | 否      | UNIQUE      | 登录名；学生使用规范化学号                          |
| account  | password_hash | VARCHAR(255) | 否      | -           | 存储带参数和随机盐的 PBKDF2 字符串                  |
| account  | role          | VARCHAR(16)  | 否      | CHECK       | ADMIN 或 STUDENT，与 student_sno 联合约束     |
| account  | student_sno   | INT          | 是      | UNIQUE / FK | 引用 student.sno；ADMIN 必须为空，STUDENT 必须非空 |
| account  | auth_version  | INT          | 否      | DEFAULT 0   | 改密递增，用于撤销旧会话                           |
| app_seed | id            | INT          | 否      | PK          | 演示数据初始化标记                              |

关系说明：student 1 → account 0..1；管理员账户不关联学生。删除账户与学生在同一服务事务完成。

初始化说明：仅新数据卷执行建表；Hibernate validate 只检查结构。app\_seed 与示例账户共同提交，避免重启覆盖修改。

## 附录 B 功能接口与输入规则

路由均相对于 /studentManagerSix；依据 StudentServlet、WebSecurityFilter 和 Validation 核对。

| 路由               | 方法         | 权限    | 功能与行为                                |
|------------------|------------|-------|--------------------------------------|
| /                | GET        | 按会话判断 | 入口导航；按登录状态和角色跳转                      |
| /login           | GET / POST | 公共    | 登录页面及认证；POST 要求 CSRF；成功更换 Session ID |
| /register        | GET / POST | 公共    | 学生注册；角色固定 STUDENT；忽略角色注入             |
| /logout          | POST       | 已登录   | 退出；要求 CSRF；撤销会话                      |
| /students        | GET        | 管理员   | 搜索与分页列表；学号精确、姓名文字搜索；每页10条            |
| /students/detail | GET        | 管理员   | 档案详情；不存在返回404                        |
| /students/create | GET / POST | 管理员   | 建立学生及账户；同一事务；重复学号409                 |
| /students/edit   | GET / POST | 管理员   | 修改学生资料；学号不可改                         |
| /students/delete | POST       | 管理员   | 删除账户及档案；同一事务；GET 返回405               |
| /profile         | GET / POST | 学生本人  | 本人资料维护；目标来自 Identity；不采用请求学号         |
| /password        | GET / POST | 已登录   | 修改密码；auth_version 递增，旧会话失效           |
| /health          | GET        | 公共    | 数据库支持的健康状态；成功返回200与OK                |

### 输入规则与实现细节

学号为1-2147483647的整数；姓名必填且至多20个 Unicode 码点，地址至多50个 Unicode 码点，文本先 strip；年龄1-150。密码按 Java String.length() 检查8-128个 UTF-16代码单元，补充字符占两个代码单元。因此，密码长度与姓名、地址的计数方式并不完全相同。

空页码为1；可解析的负整数调整为1；可解析的超末页数值定位末页。超过 Java Long 可解析范围或非整数输入返回400。

错误状态：400 参数非法；401 认证失败；403 角色或 CSRF 失败；404 目标不存在；409 重复学号；500 内部错误。未登录访问受保护页重定向登录。

## 附录 C 测试证据与断言清单

依据 docs/evidence 中保存的测试结果。下列统计反映已有验收记录，未将不同执行批次合并计数。

| 测试类                            | 测试数 | 失败 | 错误 | 跳过 |
|--------------------------------|-----|----|----|----|
| com. utils. PasswordsTest      | 2   | 0  | 0  | 0  |
| com. utils. ValidationTest     | 2   | 0  | 0  | 0  |
| com. service. StudentServiceIT | 1   | 0  | 0  | 0  |
| 合计（4个单元测试 + 1个集成场景）            | 5   | 0  | 0  | 0  |

含重启 HTTP：85 项通过断言；最终页面回归：77 项通过断言。两次运行不合并为独立用例数。以下按原 JSON 顺序保留 85 项标签，含重复辅助检查。

HTTP 原始记录：docs/evidence/http-acceptance-restart.json（restart\_checked = true）

| 序号 | 原始断言标签（保留英文以便与脚本对照）                   | 结果 |
|----|---------------------------------------|----|
| 1  | Database-backed health                | 通过 |
| 2  | Anonymous access redirects            | 通过 |
| 3  | Login JSP and includes render Chinese | 通过 |
| 4  | Session cookie flags                  | 通过 |
| 5  | Content security policy               | 通过 |
| 6  | Login CSRF required                   | 通过 |
| 7  | Form renders: /login                  | 通过 |
| 8  | Incorrect password rejected           | 通过 |
| 9  | Form renders: /login                  | 通过 |
| 10 | Successful login                      | 通过 |
| 11 | Session ID rotates on login           | 通过 |
| 12 | Admin directory renders               | 通过 |
| 13 | No credentials in page                | 通过 |
| 14 | GET deletion rejected                 | 通过 |
| 15 | Delete CSRF required                  | 通过 |
| 16 | Malformed page handled                | 通过 |

| 序号 | 原始断言标签 (保留英文以便与脚本对照)                        | 结果 |
|----|---------------------------------------------|----|
| 17 | Negative page clamped                       | 通过 |
| 18 | Large page clamped                          | 通过 |
| 19 | Empty search renders                        | 通过 |
| 20 | Missing record returns 404                  | 通过 |
| 21 | Missing route returns 404                   | 通过 |
| 22 | JSP cannot be fetched directly              | 通过 |
| 23 | Form renders: /register                     | 通过 |
| 24 | Student registration succeeds               | 通过 |
| 25 | Form renders: /register                     | 通过 |
| 26 | Duplicate student rejected                  | 通过 |
| 27 | Form renders: /register                     | 通过 |
| 28 | Invalid age rejected                        | 通过 |
| 29 | Invalid form did not create a row           | 通过 |
| 30 | Form renders: /students/create              | 通过 |
| 31 | Admin creates a student                     | 通过 |
| 32 | Search results escape HTML                  | 通过 |
| 33 | Detail page renders                         | 通过 |
| 34 | Form renders: /students/edit?sno=1826279044 | 通过 |
| 35 | Admin edits student                         | 通过 |
| 36 | Form renders: /login                        | 通过 |
| 37 | Successful login                            | 通过 |
| 38 | Session ID rotates on login                 | 通过 |
| 39 | Form renders: /login                        | 通过 |
| 40 | Successful login                            | 通过 |
| 41 | Session ID rotates on login                 | 通过 |
| 42 | Student cannot list all records             | 通过 |
| 43 | Student cannot read another record          | 通过 |

| 序号 | 原始断言标签 (保留英文以便与脚本对照)                      | 结果 |
|----|-------------------------------------------|----|
| 44 | Form renders: /profile                    | 通过 |
| 45 | Student cannot delete a record            | 通过 |
| 46 | Form renders: /profile                    | 通过 |
| 47 | Student cannot edit through admin route   | 通过 |
| 48 | Profile ignores untrusted student ID      | 通过 |
| 49 | Form renders: /profile                    | 通过 |
| 50 | Profile updates current identity only     | 通过 |
| 51 | Other student remains unchanged           | 通过 |
| 52 | Current student updated                   | 通过 |
| 53 | Form renders: /password                   | 通过 |
| 54 | Password confirmation checked             | 通过 |
| 55 | Form renders: /password                   | 通过 |
| 56 | Current password checked                  | 通过 |
| 57 | Form renders: /password                   | 通过 |
| 58 | Password change succeeds                  | 通过 |
| 59 | Password change invalidates other session | 通过 |
| 60 | Form renders: /login                      | 通过 |
| 61 | Old password no longer works              | 通过 |
| 62 | Form renders: /login                      | 通过 |
| 63 | Successful login                          | 通过 |
| 64 | Session ID rotates on login               | 通过 |
| 65 | Form renders: /login                      | 通过 |
| 66 | Successful login                          | 通过 |
| 67 | Session ID rotates on login               | 通过 |
| 68 | Form renders: /login                      | 通过 |
| 69 | Successful login                          | 通过 |
| 70 | Session ID rotates on login               | 通过 |

| 序号 | 原始断言标签（保留英文以便与脚本对照）                            | 结果 |
|----|------------------------------------------------|----|
| 71 | Restart preserves profile and changed password | 通过 |
| 72 | Restart preserves added records                | 通过 |
| 73 | Form renders: /students                        | 通过 |
| 74 | Admin deletes student and account              | 通过 |
| 75 | Deleted account session rejected               | 通过 |
| 76 | Form renders: /login                           | 通过 |
| 77 | Deleted account cannot log in                  | 通过 |
| 78 | Deleted record is missing                      | 通过 |
| 79 | Form renders: /students                        | 通过 |
| 80 | Logout succeeds                                | 通过 |
| 81 | Logged-out session cannot access directory     | 通过 |
| 82 | Form renders: /login                           | 通过 |
| 83 | Successful login                               | 通过 |
| 84 | Session ID rotates on login                    | 通过 |
| 85 | Form renders: /students                        | 通过 |

其他证据：浏览器实际完成新增、取消删除与确认删除；桌面和手机无整页横向溢出。30分钟空闲超时仅配置核查；未做压力测试、公网部署或旧生产数据迁移。

## 附录 D 部署与复现

命令在代码主目录的 PowerShell 中执行。Docker Desktop 使用 Linux containers。复现步骤涉及启动、测试或重启对应服务；本次 PDF 整理只核对命令和已有证据。

### 1. 准备环境

Docker Desktop; Linux containers

新副本首次启动需要网络下载依赖

### 2. 配置新副本

```
Copy-Item .env.example .env
```

已有 .env 时编辑即可，不覆盖现有配置

### 3. 构建并启动

```
docker compose up --build -d --wait
```

等待 db 和 app 为 healthy

### 4. 查看状态

```
docker compose ps
```

应用默认绑定本机8080；数据库不暴露主机端口

### 5. 访问应用

```
http://localhost:8080/studentManagerSix/
```

使用首次初始化时配置的账户密码

### 6. 检查日志

```
docker compose logs --tail 80 app
```

定位启动与数据库连接错误

### 7. 单元测试

```
.\mvnw.cmd test
```

本机构建需要 JDK25

### 8. 移除旧测试容器

```
docker compose -f compose.test.yaml down
```

仅隔离测试项目，用于重新初始化临时库

## 9. 真实数据库集成

```
docker compose -f compose.test.yaml up --abort-on-container-exit --exit-code-from tests
```

独立 MySQL9.7.1 临时库，不使用演示卷

## 10. HTTP验收

```
python scripts/smoke_test.py
```

Python3.10+；创建并清理临时学生

## 11. 重启持久化验收

```
python scripts/smoke_test.py --restart
```

短暂中断本项目应用及数据库

## 12. 停止并保留数据

```
docker compose stop
```

恢复用 `docker compose start`

## 13. 本机构建 WAR

```
.\mvnw.cmd clean package
```

输出 `target/studentManagerSix.war`

## 环境与数据保留

DB\_URL、DB\_USER、DB\_PASSWORD：数据库连接；SEED\_DEMO：是否导入演示数据；DEMO\_ADMIN\_PASSWORD、DEMO\_STUDENT\_PASSWORD：仅首次初始化；COOKIE\_SECURE：HTTPS 时启用；APP\_PORT：Compose 主机端口。真实秘密不写入报告。

数据保留：student-data 命名卷；不要在保留数据时使用 `down -v`。修改 `.env` 中的初始化密码不会重置已有账户。手动部署先在独立新库执行 `docker/init/001-schema.sql`。

## 附录 E 参考资料与代码索引

工程证据优先，版本以本次交付配置为准。官方文档用于技术背景，查阅基准日期为2026年9月8日。

### [R1] 项目说明

README.md

支持内容：功能范围、构建、部署与版本

### [R2] 架构与改造说明

docs/architecture.md

支持内容：旧工程问题、架构与数据关系

### [R3] 构建与部署配置

pom.xml; Dockerfile; compose.yaml; compose.test.yaml

支持内容：实际依赖和容器版本

### [R4] 数据库结构

docker/init/001-schema.sql

支持内容：字段、键、约束及字符集

### [R5] 关键实现源码

src/main/java/com/utils/Passwords.java; src/main/java/com/utils/WebSecurityFilter.java;  
src/main/java/com/service/StudentServiceImpl.java

支持内容：密码、会话、权限及事务

### [R6] Oracle Java路线

<https://www.oracle.com/java/technologies/java-se-support-roadmap.html>

支持内容：Java平台背景

### [R7] Tomcat版本对应

<https://tomcat.apache.org/whichversion>

支持内容：Servlet/JSP容器兼容关系

### [R8] Hibernate ORM7.4

<https://hibernate.org/orm/releases/7.4/>

支持内容：ORM版本背景

## [R9] MySQL9.7手册

<https://dev.mysql.com/doc/refman/9.7/en/>

支持内容：数据库技术背景

## [R10] 验收说明及原始报告

[docs/acceptance.md](#); [docs/evidence/](#)

支持内容：JUnit、HTTP、健康及浏览器证据

## 实现文件索引

| 模块       | 文件 / 路径                                                                                          | 职责                     |
|----------|--------------------------------------------------------------------------------------------------|------------------------|
| dao      | AccountDao; StudentDao; StudentDaoHibernateImpl                                                  | 查询和持久化                 |
| pojo     | Account; Identity; PageResult; Student                                                           | 实体与请求结果模型              |
| service  | BusinessException; StudentService; StudentServiceImpl                                            | 业务规则、事务与错误             |
| servlets | StudentServlet                                                                                   | 路由和视图选择                |
| utils    | AppLifecycle; HealthProbe; HibernateSessionFactoryUtil; Passwords; Validation; WebSecurityFilter | 生命周期、健康、安全与校验          |
| 测试       | PasswordsTest; ValidationTest; StudentServiceIT                                                  | 工具类边界和真实数据库场景          |
| 页面与资源    | src/main/webapp/WEB-INF/views; src/main/webapp/assets                                            | JSP、CSS、JavaScript及SVG |
| 验收脚本     | scripts/smoke_test.py                                                                            | HTTP业务、安全与重启检查         |

# 附录 F 实际界面图录

浏览器验收截图：桌面视口1440×1000、手机视口390×844。全页截图可能高于视口。

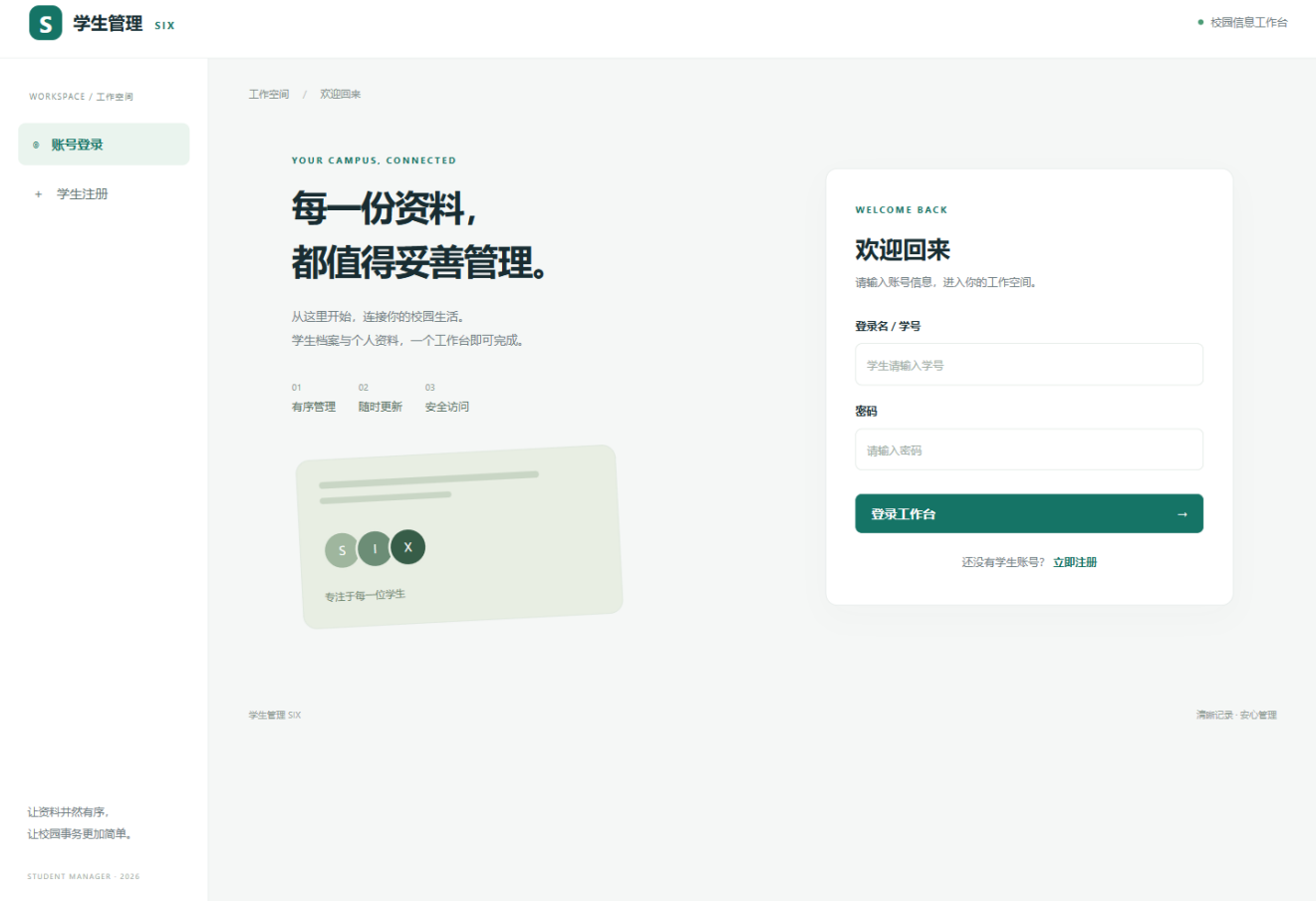


图 F-1 桌面登录页

## 附录 F 实际界面图录（续）

浏览器验收截图：桌面视口1440×1000、手机视口390×844。全页截图可能高于视口。

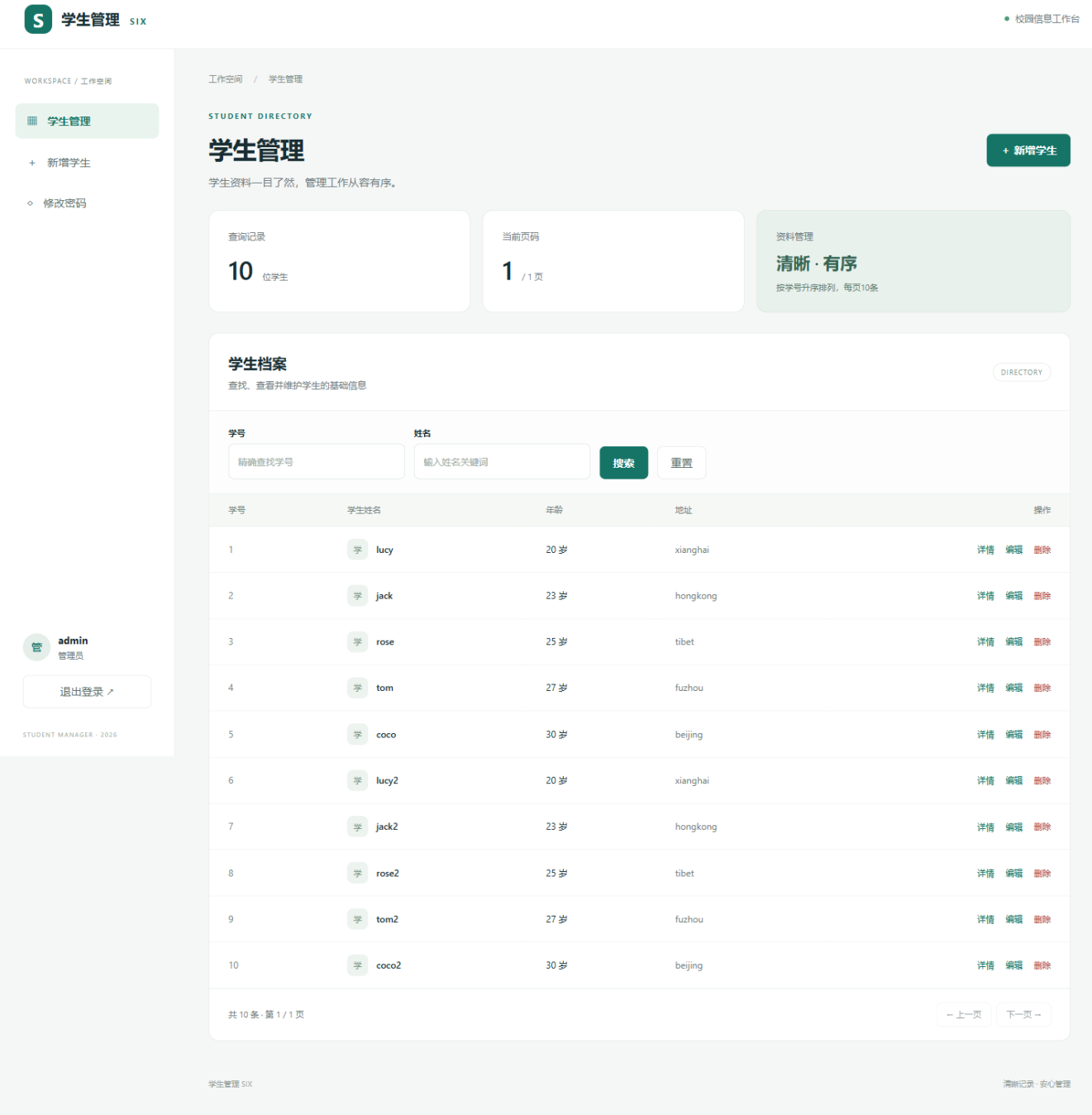


图 F-2 管理员学生列表

## 附录 F 实际界面图录（续）

浏览器验收截图：桌面视口1440×1000、手机视口390×844。全页截图可能高于视口。

S

学生管理SIX

退出登录

学生管理

+ 新增学生

◇ 修改密码

工作空间 / 新增学生

STUDENT PROFILE

返回工作台

新增学生

完善基础信息，让每一次更新都有据可循。

01

基础资料

带 \* 的项目为必填项。学号创建后不可修改。

学号 \*

例如：20260001

姓名 \*

请输入学生姓名

年龄 \*

18

地址

请输入地址（选填）

初始密码 \*

8-128个字符

学生可使用学号 and 此密码登录，登录后可修改密码。

创建学生账号

取消

学生管理SIX

图 F-3 手机端新增表单

## 附录 F 实际界面图录（续）

浏览器验收截图：桌面视口1440×1000、手机视口390×844。全页截图可能高于视口。

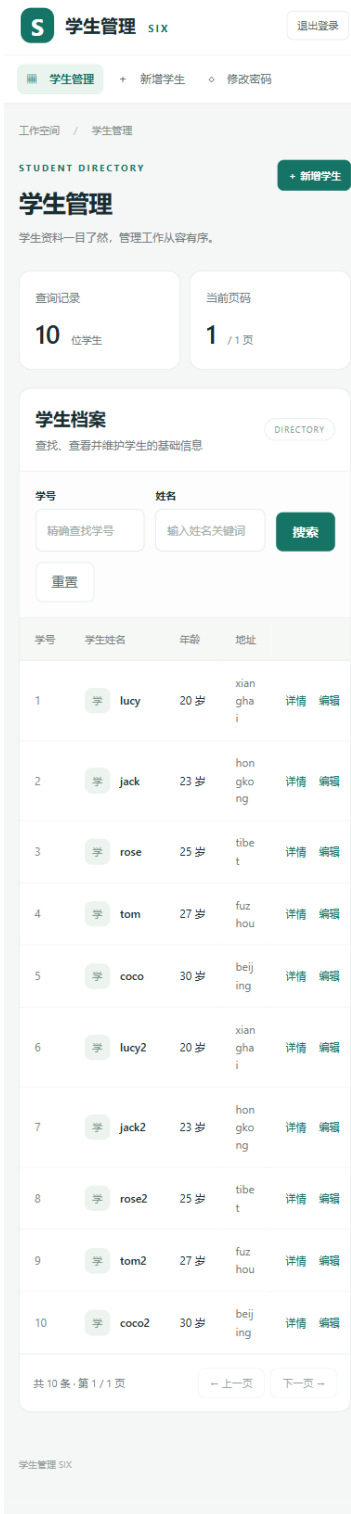


图 F-4 手机端学生列表